

Politique de Sécurité du Système d'Information

Hôpital Régional — Projet M1 CSM 2025/2026

Document	PSSI — Hôpital Régional
Version	1.0
Date	Février 2026
Auteurs	Équipe Projet — M1 Cybersécurité et Management
Établissement	EFREI Paris
Diffusion	Usage interne — Confidentiel

Dans le cadre du cours de Sécurisation des Systèmes d'Information

1. Présentation du document.....	4
1.1 Objet	4
1.2 Cadre de référence	4
2. Contexte et périmètre	4
2.1 Contexte	4
2.2 Périmètre technique.....	4
2.3 Ce qui n'est pas couvert	5
3. Identification et classification des actifs.....	5
3.1 Pourquoi classifier les actifs ?.....	5
3.2 Niveaux de classification retenus	5
3.3 Cartographie des principaux actifs	6
3.4 Schéma d'architecture.....	6
4. Règles de contrôle des accès.....	7
4.1 Gestion des identités via Active Directory	7
4.2 Politique de mots de passe.....	7
4.3 Principe du moindre privilège	7
4.4 Cycle de vie des comptes.....	8
4.5 Sécurité des postes de travail.....	8
5. Sécurité du réseau	8
5.1 Segmentation par Zones.....	8
5.2 Politique de filtrage pfSense.....	9
5.3 Accès distants et VPN	9
5.4 DNS	9
6. Protection des données.....	9
6.1 Données de santé	9
6.2 Conformité RGPD	10
6.3 Chiffrement des communications	10
6.4 Durées de conservation.....	10
6.5 Gestion des vulnérabilités	10
7. Supervision et gestion des incidents	10
7.1 Architecture de supervision	11
7.2 Sources de journaux	11
7.3 Alertes configurées.....	11
7.4 Procédure de réponse aux incidents.....	11
7.5 Indicateurs de performance sécurité (KPI).....	11
8. Sauvegarde et continuité d'activité.....	12
8.1 Stratégie de sauvegarde	12
8.2 Plan de reprise d'activité (PRA)	12

8.3 Durcissement des serveurs	13
9. Conformité réglementaire	13
9.1 ISO 27001.....	13
9.2 Directive NIS2	14
9.3 Référentiel HDS	14
10. Responsabilités.....	14
10.1 Acteurs et rôles.....	14
10.2 Charte informatique	14
10.3 Gestion des prestataires.....	15
11. Sensibilisation et Formation.....	15
11.1 Programme annuel.....	15
11.2 Simulations de phishing.....	15
11.3 Formation spécifique IT	15
12. Références	16

1. Présentation du document

1.1 Objet

Ce document constitue la Politique de Sécurité du Système d'Information (PSSI) de l'hôpital régional mis en place. Il a pour but de définir les règles et les bonnes pratiques à respecter pour assurer la protection du SI, en tenant compte des contraintes propres au milieu hospitalier.

La PSSI s'appuie sur les trois critères classiques de la sécurité de l'information, communément appelés la triade CIA :

- Confidentialité : seules les personnes autorisées peuvent accéder aux données.
- Intégrité : les données ne peuvent pas être modifiées de façon non contrôlée.
- Disponibilité : le système doit rester accessible en permanence, particulièrement pour les soins.

1.2 Cadre de référence

Pour rédiger cette PSSI, nous nous sommes appuyés sur plusieurs référentiels reconnus dans le domaine de la cybersécurité :

- La norme ISO/IEC 27001 :2022 qui encadre la mise en place d'un Système de Management de la Sécurité de l'Information (SMSI).
- Le RGPD (Règlement Général sur la Protection des Données), obligatoire pour tout traitement de données personnelles en Europe.
- La directive NIS2, qui renforce les exigences de sécurité pour les entités essentielles comme les hôpitaux.
- Le référentiel HDS (Hébergeur de Données de Santé), spécifique aux établissements de santé en France.
- Les recommandations de l'ANSSI, notamment les guides de bonnes pratiques et la méthode EBIOS Risk Manager.

2. Contexte et périmètre

2.1 Contexte

L'hôpital est classé comme Opérateur d'Importance Vitale (OIV) au sens du Code de la Défense. Cela signifie que la continuité de ses activités est considérée comme essentielle pour la nation. En conséquence, son SI doit répondre à des exigences de sécurité plus strictes que pour un organisme classique.

Dans le cadre de ce projet académique, nous simulons l'infrastructure SI d'un hôpital dans un environnement entièrement virtualisé. L'objectif est de proposer une architecture réaliste et sécurisée, même si elle ne repose pas sur du matériel physique réel.

2.2 Périmètre technique

Le périmètre couvert par cette PSSI correspond à l'ensemble de l'environnement virtualisé que nous avons mis en place. Il comprend les composants suivants :

Composant	Adresse IP	Rôle
PfSense	Passerelle Internet	Pare-feu, segmentation logique, VPN
Active Directory / DNS	10.10.60.10	Gestion des identités et des accès, résolution de noms
Serveur de supervision / SIEM	10.10.60.20	Collecte des logs, supervision réseau, détection d'incidents
Serveur de fichiers	10.10.60.30	Stockage des dossiers patients et données médicales
Serveur de sauvegarde	10.10.60.40	Sauvegardes régulières, support PRA
Poste Admin + Postes soignants	10.10.60.50	Postes de travail utilisateurs

Le réseau est segmenté logiquement via des règles de filtrage sur pfSense, simulant des zones (administration, médical, supervision, sauvegarde).

2.3 Ce qui n'est pas couvert

Nous précisons que cette PSSI ne couvre pas les infrastructures physiques réelles ni les applications médicales commerciales (type DPI ou PACS). Ces éléments sont simulés dans notre environnement de test.

3. Identification et classification des actifs

3.1 Pourquoi classifier les actifs ?

Avant de définir des mesures de sécurité, il est nécessaire de savoir ce que l'on cherche à protéger et quel est le niveau de sensibilité de chaque élément. La classification des actifs permet de prioriser les efforts et les ressources selon l'importance de chaque composant pour l'hôpital.

3.2 Niveaux de classification retenus

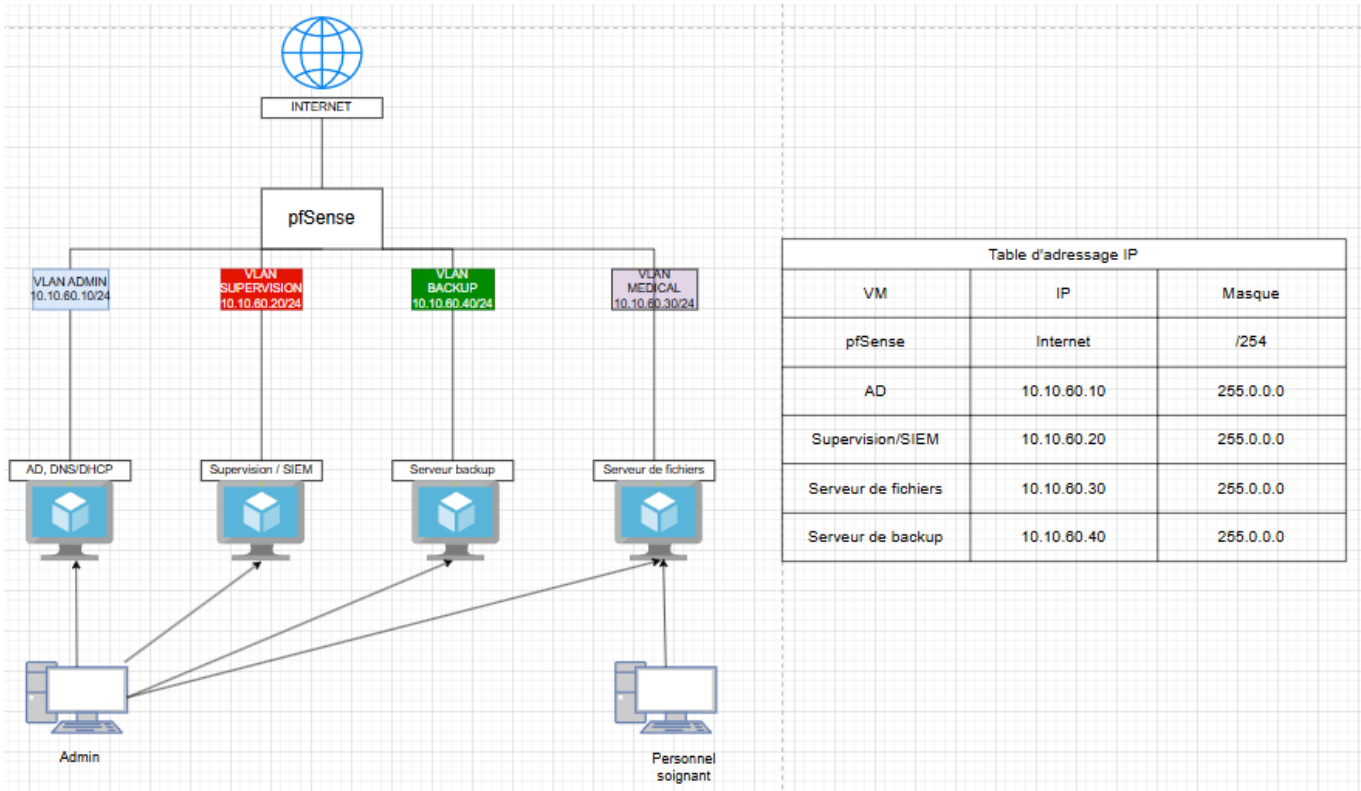
Nous avons retenu quatre niveaux de classification, inspirés des pratiques courantes en sécurité de l'information :

Niveau	Désignation	Description et exemples
4	Critique	Données dont la perte ou la compromission aurait un impact direct sur la sécurité des patients. Ex : dossiers patients, prescriptions, données médicales.
3	Sensible	Données et systèmes importants pour le fonctionnement du SI. Ex : Active Directory, fichiers de configuration pfSense, logs SIEM.
2	Interne	Informations à usage interne uniquement, sans impact critique en cas de divulgation. Ex : plannings du personnel, données RH non médicales.
1	Public	Informations pouvant être diffusées librement. Ex : horaires d'ouverture, informations de contact.

3.3 Cartographie des principaux actifs

Actif	Type	Niveau	Propriétaire
Dossiers patients (serveur fichiers : 10.10.60.30)	Donnée	4 – Critique	Direction médicale
Active Directory (10.10.60.10)	Système	3 – Sensible	Équipe IT
Pare-feu pfSense	Réseau	3 – Sensible	Équipe IT
Supervision (10.10.60.20)	Système	3 – Sensible	Équipe IT
Serveur de sauvegarde (10.10.60.40)	Système	3 – Sensible	Équipe IT
Données RH non médicales	Donnée	2 – Interne	DRH

3.4 Schéma d’architecture



(VLAN → Zones de segmentation de pfSense)

4. Règles de contrôle des accès

4.1 Gestion des identités via Active Directory

Tous les accès au SI de l'hôpital sont centralisés et gérés via le contrôleur de domaine Active Directory (10.10.60.10). Chaque utilisateur dispose d'un compte nominatif unique. Les comptes partagés ou génériques sont interdits, sauf exception justifiée et documentée.

L'arborescence Active Directory est organisée en Unités Organisationnelles (OU) selon les services :

- OU Médecins : accès lecture/écriture sur les dossiers patients de leur service.
- OU Personnel soignant : accès lecture/écriture limité selon l'unité de soins.
- OU Administratifs : accès aux ressources administratives uniquement, pas aux données médicales.
- OU Administrateurs IT : comptes techniques dédiés, séparés des comptes personnels. Ces comptes ont des droits élevés uniquement sur les systèmes qui les concernent.

Afin de renforcer la sécurité du système d'information, un principe de séparation des privilèges et de moindre privilège est appliqué. Les droits sont attribués en fonction des besoins métiers et strictement limités aux ressources nécessaires.

Les règles suivantes sont appliquées :

- Les utilisateurs ne disposent pas de droits d'administration locale sur leurs postes de travail.
- L'accès aux serveurs critiques est restreint selon les rôles et les besoins fonctionnels.
- Les comptes administrateurs sont séparés des comptes utilisateurs standards.
- Les accès aux ressources sensibles sont contrôlés via les groupes Active Directory avec des groupes Unix mirrorant les groupes de l'AD.

Cette organisation permet de limiter les risques d'escalade de privilèges et de mouvement latéral au sein du système d'information.

4.2 Politique de mots de passe

La politique de mots de passe est appliquée via les GPO Active Directory. Les règles suivantes sont en vigueur :

- Longueur minimale : 12 caractères.
- Complexité obligatoire : au moins une majuscule, une minuscule, un chiffre et un caractère spécial.
- Durée de validité : 60 jours pour tous les comptes.
- Historique : les 24 derniers mots de passe ne peuvent pas être réutilisés.
- Verrouillage automatique après 5 tentatives échouées, avec déverrouillage au bout de 10 minutes.

4.3 Principe du moindre privilège

Chaque utilisateur ne doit avoir accès qu'aux ressources strictement nécessaires à son travail. Ce principe, appelé « moindre privilège », est appliqué à travers le modèle RBAC (Role-Based Access Control) : les droits sont attribués aux groupes, et les utilisateurs sont placés dans les groupes correspondant à leur rôle.

Afin de limiter la propagation d'une compromission interne (comme un ransomware ou vol d'identifiants), les mesures suivantes sont appliquées :

- Blocage des communications SMB poste-à-poste dans la Zone MEDICAL.
- Activation et configuration du pare-feu Windows sur tous les postes clients.
- Désactivation des protocoles obsolètes (SMBv1, LLMNR).
- Restriction des connexions RDP aux seuls administrateurs IT.
- Filtrage strict des flux par pfSense.

Ces dispositions permettent de réduire significativement le risque de propagation automatique d'un malware au sein du SI hospitalier.

4.4 Cycle de vie des comptes

La création, la modification et la suppression des comptes font l'objet d'une procédure formelle. Lorsqu'un employé quitte l'hôpital ou change de poste, son compte est désactivé dans les 24 heures. Une revue mensuelle des comptes inactifs est effectuée par l'équipe IT.

4.5 Sécurité des postes de travail

Tous les postes du personnel soignant et administratif sont administrés via une gestion centralisée des configurations (GPO de l'Active Directory).

Chaque poste est équipé d'un agent de supervision permettant la collecte des journaux système et la détection d'événements suspects (exécution de processus inhabituels, erreurs système, tentatives d'authentification échouées). Ces informations sont centralisées pour analyse sur le serveur de supervision.

L'utilisation des droits administrateurs locaux est strictement interdite pour les utilisateurs standards, et les périphériques externes (clés USB) sont soumis à des règles de contrôle afin de limiter les risques d'introduction de logiciels malveillants.

Tout équipement présentant des vulnérabilités critiques ou un système d'exploitation non maintenu par l'éditeur est isolé dans une zone de quarantaine, sans accès direct aux ressources internes ni à Internet.

5. Sécurité du réseau

5.1 Segmentation par Zones

Le réseau de l'hôpital est divisé en quatre zones distinctes par règles, administrés par pfSense. Cette segmentation logique par règles permet d'isoler les différentes zones fonctionnelles et de limiter la propagation d'une attaque en cas de compromission d'un segment.

Zone	Nom	Adresse IP	Équipements concernés
10	ADMIN	10.10.60.10/24	AD, DNS, postes administrateurs IT
20	SUPERVISION	10.10.60.20/24	Serveur de journalisation et supervision
30	MEDICAL	10.10.60.30/24	Serveur de fichiers, postes du personnel soignant

40	BACKUP	10.10.60.40/24	Serveur de sauvegarde uniquement
----	--------	----------------	----------------------------------

5.2 Politique de filtrage pfSense

PfSense est configuré avec une politique de type « tout est interdit par défaut ». Seuls les flux explicitement autorisés par une règle sont acceptés. Les règles entre les différentes Zones les plus importantes sont les suivantes :

- Zone ADMIN → Zone SUPERVISION : autorisé (envoi des logs vers le SIEM).
- Zone ADMIN → Zone MEDICAL : autorisé sur les ports nécessaires à l'administration (445, 389).
- Zone MEDICAL → Zone BACKUP : interdit en accès direct. Les sauvegardes sont initiées depuis le serveur de backup uniquement.
- Internet → Zones internes : tout est bloqué, sauf le tunnel VPN entrant (OpenVPN, port 1194).

La politique de filtrage est basée sur le principe « deny by default » :

- Tout flux est interdit par défaut.
- Chaque autorisation fait l'objet d'une justification fonctionnelle documentée.
- Les flux refusés sont journalisés et analysés par le SIEM.
- Les communications directes entre Zone MEDICAL et Zone BACKUP sont interdites.
- Les ports d'administration (RDP, SSH) sont accessibles uniquement depuis la Zone ADMIN.

Cette approche permet un cloisonnement strict des différentes zones du système d'information.

5.3 Accès distants et VPN

Les accès distants au SI sont possibles uniquement via un tunnel VPN OpenVPN terminé sur pfSense. Les connexions sont authentifiées par certificat client et par identifiant/mot de passe Active Directory. Toutes les sessions sont journalisées (utilisateur, heure, IP source, durée). Les sessions inactives depuis plus de 30 minutes sont automatiquement déconnectées.

Afin de renforcer la sécurité des accès distants :

- Le split tunneling est désactivé.
- L'accès VPN est restreint aux membres d'un groupe Active Directory spécifique.
- Les connexions simultanées sont limitées.
- Les journaux VPN sont centralisés dans le SIEM pour détection d'anomalie.

Ces mesures visent à réduire les risques d'accès frauduleux ou d'exfiltration de données.

5.4 DNS

Le serveur DNS interne (10.10.60.10) est la seule source de résolution de noms pour les postes du domaine. Aucune requête DNS vers l'extérieur n'est autorisée directement depuis les postes.

6. Protection des données

6.1 Données de santé

Les données de santé sont les données les plus sensibles traitées par l'hôpital. Elles sont soumises au RGPD (catégories particulières de données, article 9) et au référentiel HDS. Nous appliquons les mesures suivantes pour les protéger :

- Chiffrement des transferts réseau : SMB 3.0 avec chiffrement activé entre les postes et le serveur de fichiers.

- Contrôle d'accès strict : seuls les membres des groupes autorisés dans l'AD qui sont mirroré dans des groupes Unix peuvent accéder aux partages médicaux.
- Journalisation des accès aux fichiers patients (audit sur le serveur de fichiers, logs remontés vers le SIEM).

Si chiffrer les données médicales est indispensable, perdre les clés de déchiffrement serait tout aussi catastrophique qu'une cyberattaque. C'est pourquoi la gestion de ces clés est centralisée dans un coffre-fort numérique (KMS). Pour anticiper le pire des scénarios, comme la compromission totale de nos serveurs d'administration, une copie de secours des clés "maîtresses" est conservée hors ligne. Elle est stockée sur un support déconnecté et placée dans un véritable coffre-fort physique. Cela garantit à l'hôpital de toujours pouvoir retrouver l'accès aux dossiers de ses patients, quoi qu'il arrive sur le réseau.

6.2 Conformité RGPD

En tant qu'établissement de santé traitant des données personnelles sensibles, l'hôpital est soumis au RGPD. Parmi les obligations applicables à notre contexte :

- Désignation d'un DPO (Délégué à la Protection des Données), obligatoire pour les établissements de santé.
- Tenue d'un registre des activités de traitement (article 30 du RGPD).
- Notification des violations de données à la CNIL dans un délai de 72 heures (article 33).
- Information des patients sur l'utilisation de leurs données.

6.3 Chiffrement des communications

Tous les protocoles en clair sont interdits sur le réseau de l'hôpital. Les protocoles FTP et Telnet sont bloqués au niveau du pare-feu. Les communications utilisent TLS 1.2 minimum (TLS 1.3 recommandé), SSH v2, et SMB 3.0 chiffré.

6.4 Durées de conservation

La durée de conservation des données respecte les textes réglementaires applicables. Le dossier médical patient est conservé 20 ans minimum après la dernière prise en charge (article R1112-7 du Code de la Santé Publique). Les journaux de sécurité sont conservés au minimum 1 an, conformément aux recommandations de l'ANSSI.

6.5 Gestion des vulnérabilités

Une politique de gestion des vulnérabilités est mise en œuvre afin d'identifier de manière proactive les failles potentielles du système d'information.

Les mesures suivantes sont appliquées :

- Réalisation des scans de vulnérabilités réguliers à l'aide d'un outil dédié.
- Classification des vulnérabilités selon leur criticité.
- Correction prioritaire des vulnérabilités critiques dans un délai maximum de 15 jours.
- Conservation des rapports de scan à des fins d'audit.

Cette démarche permet de réduire la surface d'attaque et d'anticiper les exploitations malveillantes.

7. Supervision et gestion des incidents

7.1 Architecture de supervision

Le serveur de supervision et de SIEM est hébergé dans la Zone 20 (10.10.60.20), isolé des autres Zones. Ce cloisonnement est important : si un attaquant compromet une autre Zone, il ne peut pas facilement atteindre les outils de surveillance.

Nous utilisons deux types d'outils complémentaires :

- Un outil de supervision réseau (type Zabbix) pour surveiller la disponibilité et les performances des machines (CPU, RAM, disque, état des interfaces réseau).
- Un outil de journalisation et de détection SIEM (type Wazuh) pour collecter et analyser les journaux d'événements de sécurité de l'ensemble des équipements.

7.2 Sources de journaux

Les équipements suivants envoient leurs logs vers le SIEM de façon centralisée :

- PfSense : connexions autorisées et refusées, authentications VPN, modifications de configuration.
- Active Directory : connexions réussies et échouées, modifications de comptes, changements de GPO.
- Serveur de fichiers : accès aux dossiers partagés, modifications de permissions.

7.3 Alertes configurées

Le dispositif de supervision de sécurité repose sur la centralisation des journaux via la solution Wazuh.

Dans la configuration actuelle, la solution permet la détection d'événements de sécurité significatifs à partir des logs collectés, notamment :

- Tentatives répétées d'authentification échouée.
- Authentifications réussies sur des comptes sensibles.
- Accès aux ressources partagées critiques.
- Événements système inhabituels ou suspects.

7.4 Procédure de réponse aux incidents

En cas d'alerte, nous suivons une procédure en quatre étapes, inspirée du cycle PICERL :

- Identification : qualifier l'alerte, déterminer si c'est un vrai incident ou un faux positif.
- Confinement : isoler le système ou le compte concerné pour limiter la propagation (exemple : blocage d'une IP sur pfSense, désactivation d'un compte AD).
- Éradication et rétablissement : supprimer la cause du problème, restaurer depuis une sauvegarde propre si nécessaire.
- Retour d'expérience : documenter l'incident, analyser ce qui a fonctionné ou non, mettre à jour les règles du SIEM si besoin.

7.5 Indicateurs de performance sécurité (KPI)

Afin de mesurer l'efficacité du dispositif de sécurité mis en place et d'assurer une amélioration continue, un ensemble d'indicateurs clés de performance (KPI) est défini et suivi régulièrement.

Ces indicateurs permettent d'objectiver le niveau de sécurité du SI, d'identifier les axes de progression et de fournir une vision synthétique à la direction et au RSSI. Ils couvrent à la fois la disponibilité des services, la capacité de détection et de réponse aux incidents, ainsi que le respect des engagements en matière de sauvegarde, de gestion des accès et de sensibilisation du personnel. En cas de dépassement

d'un seuil cible, une action corrective est engagée et documentée dans le cadre du plan d'amélioration continue de la PSSI.

Indicateur	Mesure	Cible	Fréquence
Taux de disponibilité du SI	Uptime des services critiques	> 99,5%	Mensuel
Délai moyen de détection d'incident (MTTD)	Temps entre occurrence et alerte	< 30 min	Mensuel
Délai moyen de résolution d'incident (MTTR)	Temps entre alerte et résolution	< 4h (P1)	Mensuel
Nombre de tentatives de brute force détectées	Nombre d'échecs d'authentification	Suivi tendance	Hebdomadaire
Taux de comptes inactifs non désactivés	Revue AD mensuelle	0%	Mensuel
Taux de sauvegardes vérifiées avec succès	Tests d'intégrité Restic	100%	Hebdomadaire
Délai de correction des vulnérabilités critiques	Scan → patch appliqué	< 15 jours	Par vulnérabilité
Taux de personnel sensibilisé	Formation annuelle complétée	> 95%	Annuel

8. Sauvegarde et continuité d'activité

8.1 Stratégie de sauvegarde

La sauvegarde constitue un élément essentiel pour garantir la disponibilité et l'intégrité des données, notamment en cas d'attaque par ransomware ou de panne matérielle.

Nous appliquons la règle 3-2-1 :

- 3 copies des données au minimum.
- Sur 2 supports différents.
- 1 copie isolée, stockée dans la Zone BACKUP (40), isolé des autres Zones.

Pour sécuriser les données critiques, nous avons choisi Restic, solution de sauvegarde open source et facile à utiliser. La politique de sauvegarde est la suivante :

- Sauvegarde incrémentale : chaque soir, à 22h, stockant uniquement les modifications depuis la dernière sauvegarde complète ou incrémentale.
- Rétention : 4 semaines de sauvegardes journalières, 3 mois de sauvegardes hebdomadaires, 1 an de sauvegardes mensuelles.
- Données sauvegardées : configurations AD, contenu du serveur de fichiers (dossiers patients).
- Chiffrement : AES-256 pour toutes les sauvegardes.
- Vérification : intégrité des sauvegardes contrôlée chaque semaine.

8.2 Plan de reprise d'activité (PRA)

Nous avons défini des objectifs de reprise pour les services les plus critiques du SI :

Service	RTO cible	RPO cible	Priorité
Accès aux dossiers patients	< 30 minutes	< 1 heure	P1
Active Directory (authentification)	< 1 heure	< 4 heures	P1
Pare-feu pfSense	< 1 heure	Snapshot	P1
SIEM / Supervision	< 4 heures	< 24 heures	P2

Ces RTO et RPO sont testés régulièrement dans l'environnement virtualisé pour vérifier que les procédures de restauration fonctionnent correctement. Les résultats des tests sont documentés.

Restic permet la restauration rapide des données et que les tests de PRA incluent la restauration depuis Restic pour vérifier l'intégrité et le RPO/RTO.

Un plan de revue de la PSSI de façon annuelle est aussi mis en place.

8.3 Durcissement des serveurs

Les serveurs critiques du SI (Active Directory, serveur de fichiers, serveur SIEM, serveur de sauvegarde) sont déployés sur des machines virtuelles et font l'objet d'un durcissement adapté à un niveau moyen :

- Système à jour : tous les serveurs sont maintenus avec les derniers correctifs de sécurité.
- Séparation des comptes et privilèges : application d'un principe de moindre privilège avec distinction entre comptes administrateurs et comptes utilisateurs.
- Politiques de sécurité via GPO : mots de passe forts, verrouillage automatique après tentatives échouées, expiration régulière.
- Chiffrement des volumes : chiffrement AES-256 sur les sauvegardes Restic ; chiffrement des volumes est prévu en déploiement production.
- Accès réseau restreint : VPN obligatoire pour les accès distants, filtrage entre les différentes zones strict via pfSense.
- Supervision des systèmes : suivi de la disponibilité et des événements critiques via les outils de supervision et de centralisation des journaux.
- Services minimaux activés : seuls les services nécessaires sont activés sur chaque VM pour réduire la surface d'attaque.
- Sauvegardes sécurisées : toutes les données sont sauvegardées régulièrement avec Restic, chiffrées et stockées dans la Zone BACKUP, avec vérification d'intégrité hebdomadaire.

Cette approche garantit un niveau de sécurité adapté à notre environnement académique tout en restant simple à mettre en œuvre et compatible avec nos ressources limitées.

9. Conformité réglementaire

9.1 ISO 27001

Notre PSSI s'aligne sur les grands principes de la norme ISO 27001 :2022, même si nous ne visons pas la certification dans le cadre de ce projet académique. Voici les principaux contrôles de l'Annexe A qui correspondent aux mesures que nous avons mises en place :

Contrôle	Mesure mise en place dans notre projet
A.5.15	Contrôle d'accès via Active Directory (RBAC, GPO, principe du moindre privilège)
A.8.7	Antivirus centralisé, blocage des ports USB via GPO, politique de mises à jour
A.8.16	Centralisation des logs sur le SIEM, alertes automatiques, journalisation des accès
A.8.20	Filtrage pfSense, VPN pour les accès distants
A.8.13	Règle 3-2-1, sauvegardes chiffrées, tests de restauration réguliers

9.2 Directive NIS2

L'hôpital est une entité essentielle au sens de la directive NIS2 (secteur santé, annexe I). Les principales obligations de NIS2 qui s'appliquent à notre contexte sont :

- Mettre en place une gestion des risques documentée, couverte par notre analyse de risques.
- Notifier les incidents significatifs à l'ANSSI sous 24 heures (alerte initiale), puis sous 72 heures (rapport complet).
- Sécuriser la chaîne d'approvisionnement, notamment les accès des prestataires.

9.3 Référentiel HDS

L'hébergement de données de santé est encadré en France par la certification HDS. Bien que notre environnement soit virtualisé et académique, nous nous appuyons sur les exigences HDS comme référence pour évaluer la robustesse de notre architecture, notamment en ce qui concerne la sécurité physique des serveurs, la traçabilité des accès et la gestion des sauvegardes.

10. Responsabilités

10.1 Acteurs et rôles

La sécurité du SI est l'affaire de tous. Chaque acteur a un rôle précis dans la mise en œuvre et le respect de cette PSSI :

- Direction Générale : valide et soutient la PSSI, alloue les ressources nécessaires, est informée en cas d'incident majeur.
- RSSI (Responsable Sécurité SI) : pilote la PSSI, coordonne la réponse aux incidents, réalise les audits de sécurité et suit les indicateurs.
- DPO (Délégué à la Protection des Données) : assure la conformité au RGPD, tient le registre des traitements, est l'interlocuteur de la CNIL.
- Équipe IT / Administrateurs : mettent en œuvre les mesures techniques, appliquent les procédures de durcissement, gèrent les mises à jour et les incidents.
- Utilisateurs (personnel médical, administratif) : respectent les règles d'usage définies dans la charte informatique, signalent tout comportement suspect.

10.2 Charte informatique

Une charte informatique est remise et signée par tout utilisateur ayant accès au SI de l'hôpital. Elle précise les droits et les obligations de chacun : interdiction de partager son mot de passe, de connecter des équipements personnels non autorisés, de désactiver les outils de sécurité, ou d'accéder à des ressources qui ne relèvent pas de ses fonctions.

10.3 Gestion des prestataires

Les prestataires intervenant sur le SI font l'objet d'un encadrement contractuel. Les accès distants de maintenance sont accordés via des comptes VPN temporaires, créés pour la durée de l'intervention et désactivés immédiatement après. Toutes les actions effectuées pendant la session sont journalisées.

11. Sensibilisation et Formation

La sécurité du SI repose en grande partie sur le comportement des utilisateurs. Un programme de sensibilisation annuel est mis en place.

Cette démarche répond notamment aux exigences du RGPD et de la directive NIS2 Directive.

11.1 Programme annuel

Afin de maintenir un niveau de sécurité opérationnel, chaque agent (médical, administratif et technique) doit suivre un cursus de sensibilisation obligatoire intégrant :

- Hygiène Numérique : Gestion rigoureuse des identifiants et verrouillage systématique des sessions en zone de soins.
- Ingénierie sociale : Méthode de détection des mails de phishing et des tentatives d'usurpation d'identité (faux support technique).
- Réflexes incidents logiques : procédure d'alerte immédiate en cas d'anomalie sur un poste de travail pour limiter la propagation (isolation du poste).
- Protection du dossier patient informatisé (DPI) : rappel des enjeux juridiques et éthiques liés à la confidentialité des données de santé.
- Support de référence : diffusion d'un guide de survie cyber personnalisé aux métiers de l'hôpital.

11.2 Simulations de phishing

Pour tester l'efficacité du programme et la réactivité des équipes face au risque d'intrusion :

- Immersion réelle : organisation de simulation de phishing calquées sur des menaces réelles (comme de fausse mise à jour de logiciel de santé).
- Analyse de la menace : mesure du taux de clic et de compromission pour identifier les services les plus vulnérables.
- Pédagogie positive : les résultats sont anonymisés et servent de base à des ateliers de renforcement, sans mesure disciplinaire, pour encourager la culture du signalement.

11.3 Formation spécifique IT

Les administrateurs système et réseau bénéficient des formations avancées :

- Maintien en Condition de Sécurité (MCS) : Formations spécialisées sur la sécurisation des infrastructures critiques et des objets connectés médicaux (IoT).

- Veille Stratégique : Suivi des bulletins d'alerte de l'ANSSI et du CERT-Santé pour anticiper les vulnérabilités 0-day.
- Entraînement à la Crise : Exercices réguliers de type "Cyber Range" (simulation de ransomware) pour tester les procédures de restauration (Plan de Reprise d'Activité) et la coordination en mode dégradé.

12. Références

Voici les principales sources utilisées pour la rédaction de cette PSSI :

- ISO/IEC 27001 :2022 — Système de Management de la Sécurité de l'Information.
- ISO/IEC 27002 :2022 — Mesures de sécurité de l'information.
- Directive NIS2 (UE 2022/2555) — Sécurité des réseaux et des systèmes d'information.
- RGPD (UE 2016/679) — Protection des données à caractère personnel.
- Référentiel HDS — Certification Hébergeur de Données de Santé.
- PGSSI-S (Politique Générale de Sécurité des SI de Santé) — ASIP Santé / ANS.
- Guide EBIOS Risk Manager — ANSSI, 2018.
- Guide d'hygiène informatique — ANSSI.
- Code de la Santé Publique — Articles R1112-1 et suivants.

Document réalisé dans le cadre du projet de sécurisation du SI — M1 Cybersécurité et Management — EFREI Paris — 2025/2026